

透過 Identity-Aware Proxy 驗證使用者身分

來源：<https://codelabs.developers.google.com/codelabs/user-auth-with-iap?hl=zh-tw>

步驟數：7

在本程式碼研究室中，您將建立網頁應用程式，僅開放指定使用者群組存取，並在程式中使用已驗證使用者的身分

目錄

1. [1. 簡介](#)
2. [2. 開始設定](#)
3. [3. 步驟 1：部署應用程式並使用 IAP 保護應用程式](#)
4. [4. 步驟 2 - 存取使用者身分資訊](#)
5. [5. 步驟 3 - 使用加密編譯驗證](#)
6. [6. 摘要](#)
7. [7. 清除所用資源](#)

步驟 1 · 約 2 分鐘

1. 簡介

驗證網頁應用程式使用者的身分往往是必要的，而這項作業通常需要在應用程式中特別編寫程式碼。如果是 Google Cloud Platform 應用程式，則可交由 **Identity-Aware Proxy** 服務進行身分驗證。若只需要限制特定使用者的存取權，則無須對應用程式進行任何變更。如果應用程式需要知道使用者的身分 (例如為了將使用者偏好保留於伺服器端)，則 Identity-Aware Proxy 可運用最少的應用程式程式碼提供這項資訊。

什麼是 Identity-Aware Proxy ?

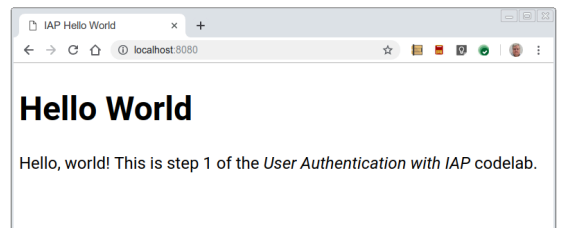
Identity-Aware Proxy (IAP) 是一項 Google Cloud Platform 服務，可攔截傳送至應用程式的網頁要求，使用 Google Identity 服務對發出請求的使用者進行身分驗證，並只允許您授權的使用者所傳送的要求。此外，這項功能還能修改要求標頭，加入已驗證使用者相關資訊。

本程式碼研究室會逐步引導您建立自己的應用程式、限制存取權，以及從 IAP 取得使用者身分。

建構目標

在本程式碼研究室中，您將透過 Google App Engine 建構簡單的網頁應用程式，並靈活運用 Identity-Aware Proxy 限制應用程式存取權，以及向應用程式提供使用者身分資訊。您的應用程式將會：

- 顯示歡迎頁面
- 存取 IAP 提供的使用者身分資訊
- 採用加密編譯驗證，防止使用者身分資訊遭到假冒



課程內容

- 如何使用 Python 3.7 編寫及部署簡單的 App Engine 應用程式
- 如何啟用和停用 IAP 以限制應用程式存取權
- 如何透過 IAP 取得使用者身分資訊並提供給應用程式
- 如何以加密編譯的方式驗證 IAP 提供的資訊，防範假冒行為

軟硬體需求

- 新式網路瀏覽器，例如 [Chrome](#)。
- 具備 Python 程式設計語言的基本知識

本程式碼研究室主要探討 Google App Engine 和 IAP。我們不會對與主題無關的概念和程式碼多做介紹，但會事先準備好這些程式碼區塊，屆時您只要複製及貼上即可。

步驟 2 · 約 3 分鐘

2. 開始設定

您將在 Cloud Shell 指令列環境中作業。首先，請開啟該環境並擷取程式碼範例。

啟動 Cloud Shell

在實驗室頁面的左上方，按一下「Open Google Console」按鈕。您必須使用該按鈕下方顯示的使用者名稱和密碼登入。

Open Google Console

Caution: When you are in the console, do not deviate from the lab instructions. Doing so may cause your account to be blocked.

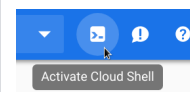
Username
.....

Password
.....

GCP Project ID
.....

[New to labs? View our introductory video!](#)

本程式碼研究室的所有指令都會在為您建立及開啟的專案中，透過 Cloud Shell 執行。按一下控制台頁面標題右側的「啟用 Cloud Shell」圖示，開啟 Cloud Shell。您可以在頁面下半部輸入及執行指令。指令可從您的電腦執行，但您必須先安裝及設定所需的開發軟體。Cloud Shell 已具備所有必要的軟體工具。



下載程式碼

按一下 Cloud Shell 中的指令列區域，即可輸入指令。從 GitHub 擷取程式碼，然後切換至程式碼資料夾：

```
git clone https://github.com/googlecloudlabs/user-authentication-with-iap.git
cd user-authentication-with-iap
```

這個資料夾包含本程式碼研究室每個步驟的子資料夾。您必須切換至正確的資料夾才能執行每個步驟。

步驟 3 · 約 10 分鐘

3. 步驟 1：部署應用程式並使用 IAP 保護應用程式

這是以 Python 3.7 編寫的 App Engine 標準環境應用程式，只會顯示「Hello, world」歡迎頁面。我們會部署並測試應用程式，然後使用 IAP 限制相關存取權。

查看應用程式程式碼

從主要專案資料夾切換至包含此步驟程式碼的 **1-HelloWorld** 子資料夾。

```
cd 1-HelloWorld
```

應用程式程式碼位於 **main.py** 檔案中。這個檔案使用 [Flask](#) 網路框架，透過範本內容回應網頁要求。該範本檔案位於 **templates/index.html**，在這個步驟中僅包含純 HTML。第二個範本檔案則位於 **templates/privacy.html**，內含簡略的隱私權政策範例。

另外還有兩個檔案：一個是 **requirements.txt**，當中列出應用程式使用的所有非預設 Python 程式庫，另一個是 **app.yaml**，用來指示 Google Cloud Platform 這是 Python 3.7 App Engine 應用程式。

您可以使用 `cat` 指令在殼層中列出每個檔案，如下所示：

```
cat main.py
```

或者，您也可以點選 Cloud Shell 視窗右上角的鉛筆圖示，開啟 Cloud Shell 程式碼編輯器，以此方式檢查程式碼。

在這個步驟中，您不需要變更任何檔案。

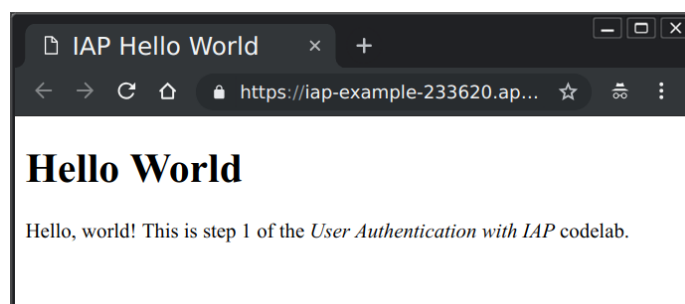
部署至 App Engine

接下來，要將應用程式部署至 Python 3.7 適用的 App Engine 標準環境。

```
gcloud app deploy
```

系統可能會要求您選擇部署目標區域。選取附近「支援標準」的任何一個。當系統詢問是否要繼續時，請輸入「**y**」表示同意。

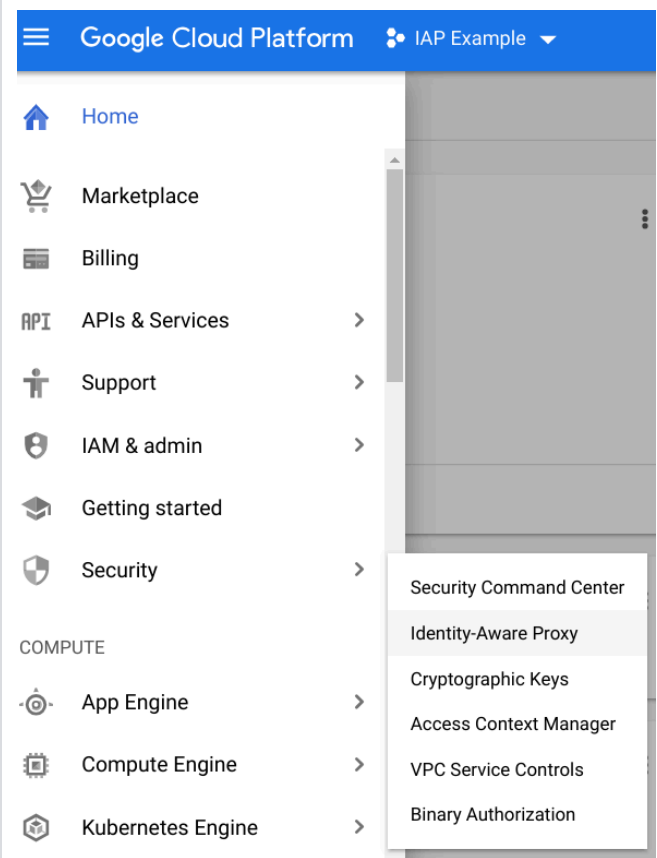
部署作業會在幾分鐘內完成，屆時畫面上將出現訊息，提示您使用 `gcloud app browse` 查看應用程式。輸入該指令。如果瀏覽器未開啟新分頁，請點選顯示的連結，即可在新分頁中開啟；也可以視需要將連結複製到手動開啟的新分頁。由於是首次執行這個應用程式，啟動雲端執行個體時需要幾秒鐘時間才會顯示，接著您應該會看到以下視窗。



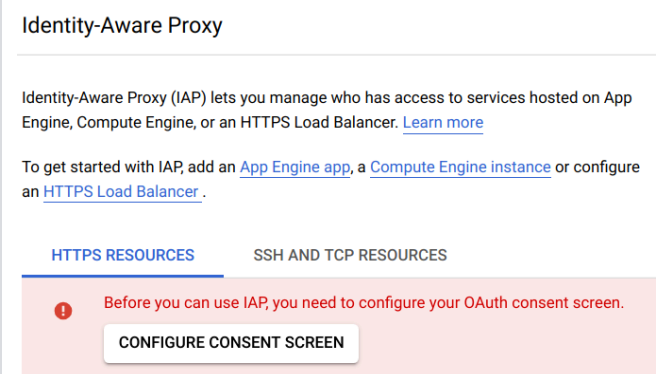
您可以在任何連線至網際網路的電腦上開啟同一個網址，查看該網頁。存取權尚未受到限制。

使用 IAP 限制存取權

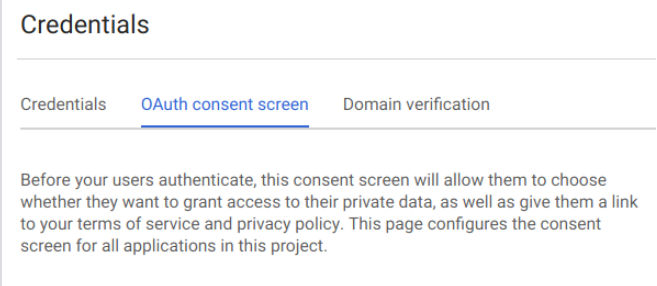
在 Cloud 控制台視窗中，按一下頁面左上角的選單圖示，依序點選「安全性」和「Identity-Aware Proxy」。



由於這是您第一次為這項專案啟用驗證選項，因此系統會顯示一則訊息，說明您必須先設定 OAuth 同意畫面，才能使用 IAP。



按一下「設定同意畫面」按鈕。系統會開啟新分頁，供您設定同意畫面。



在所需欄位中填入適當的值：

應用程式名稱	IAP 範例
支援服務電子郵件地址	你的電子郵件地址。系統可能已為你填入。
已授權網域	應用程式網址的主機名稱部分，例如 <code>iap-example-999999.appspot.com</code> ，這個網域會顯示在先前開啟的 <code>Hello World</code> 網頁網址列中。請不要在該網址開頭加上 <code>https://</code> ，或在結尾加上 <code>/</code> 。填寫完這個值後，請務必按下 Enter 鍵 。
應用程式首頁連結	您用來查看應用程式的網址
應用程式隱私權政策連結	應用程式中的隱私權頁面連結與首頁連結相同，但網址結尾加上了 <code>/privacy</code>

按一下「儲存」。系統會提示您建立憑證。在本程式碼研究室中，您不需要建立憑證，只要關閉這個瀏覽器分頁即可。

返回 Identity-Aware Proxy 頁面並重新整理。接著，畫面上會列出您可以保護的資源。按一下「App Engine 應用程式」列中 IAP 欄的切換鈕，即可啟用 IAP。

HTTPS RESOURCES

SSH AND TCP RESOURCES

Filter tree

Resource

IAP ?

Published ?

Configuration ?

All Web Services

App Engine app

https://iapdemo-233019.appspot.com

OK

default

https://iapdemo-233019.appspot.com

Turn on IAP

This will only allow access to App Engine app by members listed in the permission panel.

Enter the domain names used to access this resource: ?

iapdemo-233019.appspot.com

iapdemo-233019.appspot-preview.com

+ ADD URI

CANCEL

TURN ON

現在開啟瀏覽器分頁並前往應用程式的網址。系統會顯示「使用 Google 帳戶登入」畫面，您必須登入才能存取應用程式。

 Sign in with Google

Sign in

to continue to iapdemo-233019.appspot.com

Email or phone

[Forgot email?](#)

[Create account](#)

Next

English (United States) ▼

[Help](#)

[Privacy](#)

[Terms](#)

使用 Google 或 G Suite 帳戶登入。畫面會顯示「拒絕存取」。



You don't have access

[Troubleshooting Info](#)

User:

`gcpstaging54053_student@qwiklabs.net`

URL:

`https://qwiklabs-gcp-6824a7336c8ebd43.appspot.com/`

If you should have access, please contact gcpstaging54053_student@qwiklabs.net and provide the troubleshooting info above.

If you're signed in with multiple Google accounts, [try a different account](#).

您已成功使用 IAP 保護應用程式，但尚未指示 IAP 哪些帳戶有存取權。

返回控制台的 Identity-Aware Proxy 頁面，選取 App Engine 應用程式旁的核取方塊，然後查看頁面右側的側欄。

取得存取權的每個電子郵件地址 (或 Google 群組電子郵件地址/G Suite 網域名稱) 都必須新增為成員。按一下「新增成員」。輸入電子郵件地址，然後選取「Cloud IAP/IAP-Secured Web App User」(受 Cloud IAP/IAP 保護的網路應用程式使用者) 角色，指派給該地址。您可以用相同方式輸入多個電子郵件地址或 G Suite 網域。

App Engine app

1

Granting Owner at the *resource level* only allows modifying the access policy. It does not grant access to the application.

Edit or delete permissions below or "Add Member" to grant new

ADD MEMBER

Show inherited permissions

Filter tree

Role / Member ↑	Inheritance
Owner (1)	

Add members and roles for "App Engine app" resource

Enter one or more members below. Then select a role for these members to grant them access to your resources. Multiple roles allowed. [Learn more](#)

New members

gcpstaging54053_student@qwiklabs.net

Role

Type to filter

Project

Cloud IAP

IAM

IAP Policy Admin

IAP-secured Web App User

IAP-secured Web App User

Access HTTPS resources which use Identity-Aware Proxy

MANAGE ROLES

按一下「儲存」。系統隨即會在視窗底部顯示「已更新政策」訊息。

返回應用程式，然後重新載入頁面。您已使用授權的使用者登入，現在應該會看到網頁應用程式。不過，IAP 可能不會重新確認您的授權，因此畫面仍會顯示「You don't have access」頁面。在這種情況下，請執行下列步驟：

- 開啟網路瀏覽器，前往首頁網址，並在網址末端加上 `/_gcp_iap/clear_login_cookie`，例如 `https://iap-example-999999.appspot.com/_gcp_iap/clear_login_cookie`。
- 您會看到新的「使用 Google 帳戶登入」畫面，當中顯示您的帳戶。請不要點選該帳戶，而是點選「使用其他帳戶」，然後重新輸入憑證。
- 這些步驟會使 IAP 重新確認存取權限，您現在應該可以看到應用程式的主畫面。

如果您可以存取另一個瀏覽器或在瀏覽器中使用無痕模式，並且有其他有效的 Gmail 或 G Suite 帳戶，則可透過該瀏覽器前往應用程式頁面，然後用其他帳戶登入。由於該帳戶尚未獲得授權，因此會顯示「您沒有存取權」畫面，而不是應用程式頁面。

步驟 4 · 約 10 分鐘

4. 步驟 2 - 存取使用者身分資訊

應用程式受到 IAP 保護後，即可使用 IAP 在網頁要求標頭提供的身份資訊。在這個步驟，應用程式將取得已登入使用者的電子郵件地址，以及 Google Identity 服務指派給該使用者的永久專屬使用者 ID。系統會在歡迎頁面向使用者顯示這項資料。

這是步驟 2，上一個步驟結束時，Cloud Shell 會在 `iap-codelab/1-HelloWorld` 資料夾中開啟。切換至這個步驟的資料夾：

```
cd ~/iap-codelab/2-HelloUser
```

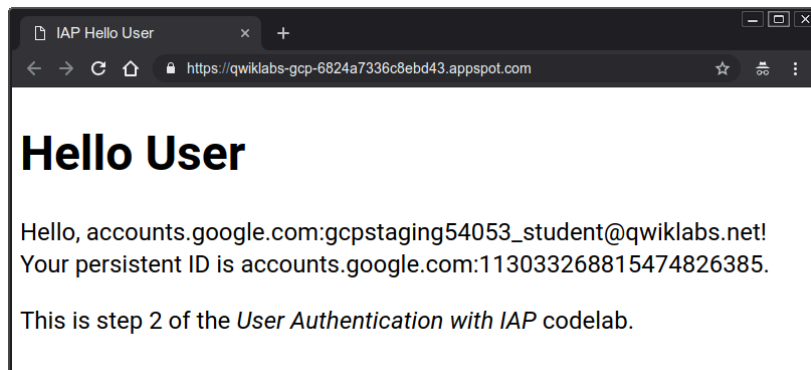
部署至 App Engine

部署作業需要幾分鐘的時間，因此請先將應用程式部署至 Python 3.7 適用的 App Engine 標準環境：

```
gcloud app deploy
```

當系統詢問是否要繼續時，請輸入「Y」表示同意。部署作業應該會在幾分鐘內完成。等待過程中，您可以按照下方說明檢查應用程式檔案。

部署作業準備就緒後，系統會顯示訊息，指示您可以使用 `gcloud app browse` 查看應用程式。輸入該指令。如果瀏覽器未開啟新分頁，請將顯示的連結複製到新分頁正常開啟。您應該會看到類似以下頁面：



系統可能需要幾分鐘，才能將先前的應用程式版本替換為新版本。請視需要重新整理頁面，以查看類似上述內容的頁面。

檢查應用程式檔案

這個資料夾包含與步驟 1 相同的一組檔案，但其中兩個檔案已變更：`main.py` 和 `templates/index.html`。該程式已改為檢索 IAP 在要求標頭中提供的使用者資訊，且範本現在也會顯示該項資料。

在 `main.py` 檔案，有兩行程式碼可取得 IAP 提供的身份資料：

```
user_email = request.headers.get('X-Goog-Authenticated-User-Email')  
user_id = request.headers.get('X-Goog-Authenticated-User-ID')
```

`X-Goog-Authenticated-User-` 標頭是由 IAP 提供，名稱不區分大小寫，您可以依需求全部小寫或大寫。
`render_template` 語句現在包含這些值，因此可以顯示：

```
page = render_template('index.html', email=user_email, id=user_id)
```

在 index.html 範本用雙大括號括住名稱，即可顯示這些值：

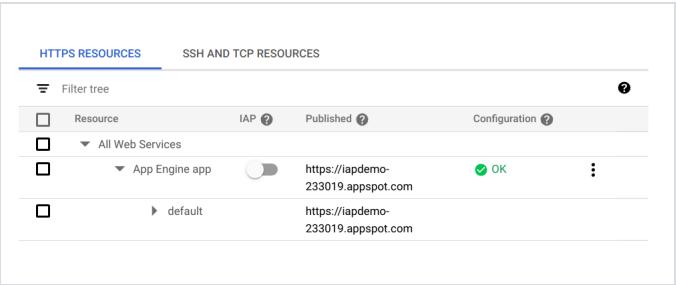
```
Hello, {{ email }}! Your persistent ID is {{ id }}.
```

如您所見，提供的資料包含 `accounts.google.com`：前置字串，顯示資訊來源。應用程式可視需要移除包括半形冒號在內的所有內容，以取得原始值。

停用 IAP

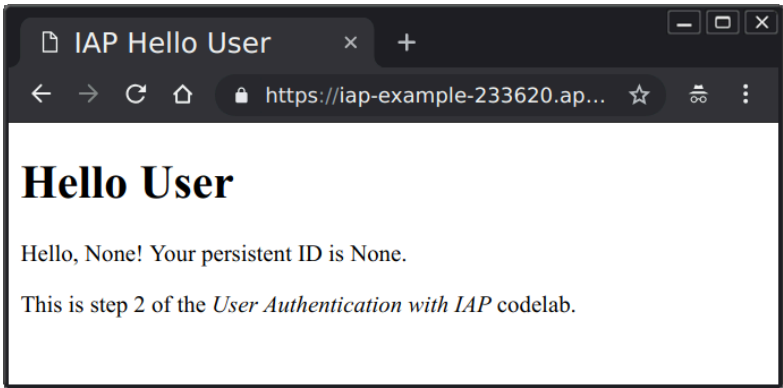
如果停用或以某種方式 (例如透過同一個雲端專案中執行的其他應用程式) 略過 IAP，會對應用程式有什麼影響？停用 IAP 以查看後續影響。

在 Cloud 控制台視窗中，按一下頁面左上角的選單圖示，依序點選「安全性」和「Identity-Aware Proxy」。點選 App Engine 應用程式旁的「IAP」切換開關，即可停用 IAP。



系統會提醒您，停用 IAP 後所有使用者都可以存取該應用程式。

重新整理應用程式網頁您應該會看到相同的頁面，但沒有顯示任何使用者資訊：



應用程式目前未受到保護，因此使用者可以發送看似透過 IAP 傳送的網頁要求。舉例來說，您可以在 Cloud Shell 中執行下列 curl 指令，完成 (將 <your-url-here> 替換成應用程式正確網址) 這項操作：

```
curl -X GET <your-url-here> -H "X-Goog-Authenticated-User-Email: totally fake email"
```

網頁會顯示在指令列中，如下所示：

```
<!doctype html>
<html>
<head>
  <title>IAP Hello User</title>
</head>
<body>
  <h1>Hello World</h1>

  <p>
    Hello, totally fake email! Your persistent ID is None.
  </p>

  <p>
    This is step 2 of the <em>User Authentication with IAP</em>
    codelab.
  </p>

</body>
</html>
```

應用程式無法知道 IAP 是否遭到停用或略過。因此，針對可能存在潛在風險的情況，步驟 3 提供瞭解解決方案。

5. 步驟 3 - 使用加密編譯驗證

如果 IAP 可能遭到停用或略過，您的應用程式可確認收到的身分資訊是否有效。方法是使用 IAP 新增的第三個網頁要求標頭，名稱為 `X-Goog-IAP-JWT-Assertion`。該標頭的值是以加密編譯方式簽署的物件，也包含使用者身分資料。應用程式可驗證數位簽章，並使用該物件中提供的資料確保這個簽章是出自 IAP，未經修改。

數位簽章驗證需要幾個額外的步驟，例如檢索最新的 Google 公開金鑰。您可以根據使用者可能停用或略過 IAP 的可能性，以及應用程式的敏感度，決定應用程式是否需要這些額外步驟。

這是步驟 3，上一個步驟結束時，Cloud Shell 會在 `iap-codelab/2-HelloUser` 資料夾中開啟。切換至這個步驟的資料夾：

```
cd ~/iap-codelab/3-HelloVerifiedUser
```

部署至 App Engine

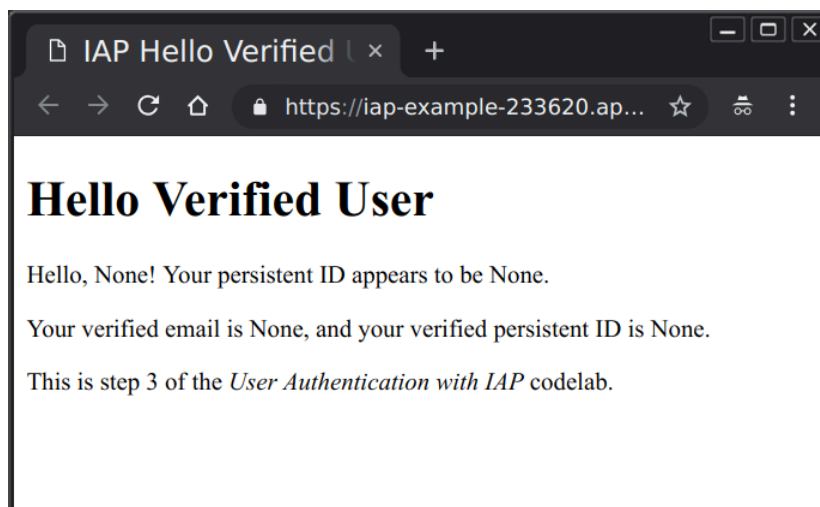
將應用程式部署至 Python 3.7 適用的 App Engine 標準環境：

```
gcloud app deploy
```

當系統詢問是否要繼續時，請輸入「Y」表示同意。部署作業應該會在幾分鐘內完成。等待過程中，您可以按照下方說明檢查應用程式檔案。

部署作業準備就緒後，系統會顯示訊息，指示您可以使用 `gcloud app browse` 查看應用程式。輸入該指令。如果瀏覽器未開啟新分頁，請將顯示的連結複製到新分頁正常開啟。

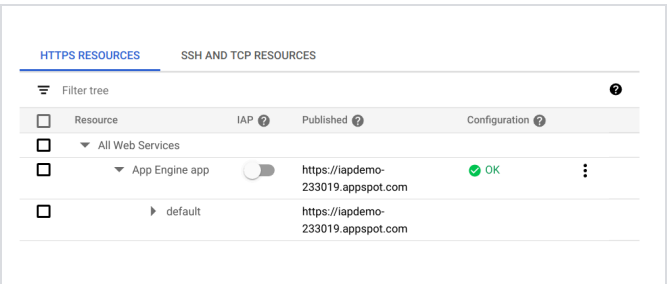
提醒您，您在步驟 2 中停用了應用程式內購，因此應用程式不會收到應用程式內購資料。您應該會看到類似以下頁面：



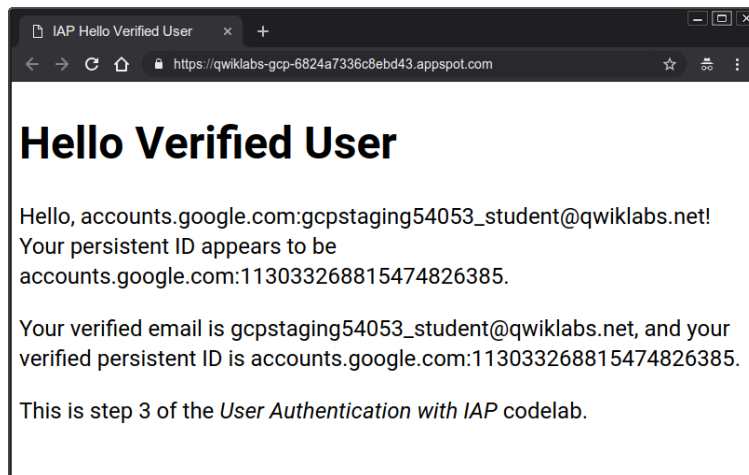
如同之前的情況，系統可能需要幾分鐘才能將最新版本上線，屆時才能看到新版頁面。

IAP 已停用，因此沒有提供使用者資訊。現在重新啟用 IAP。

在 Cloud 控制台視窗中，按一下頁面左上角的選單圖示，依序點選「安全性」和「Identity-Aware Proxy」。點選 App Engine 應用程式旁的「IAP」切換開關，即可重新啟用 IAP。



重新整理頁面。頁面應如下所示：



請注意，經驗證方法提供的電子郵件地址不含 `accounts.google.com:` 前置字串。

如果停用或略過 IAP，經過驗證的資料會遺失或失效，原因是不具備有效簽章，除非是由 Google 私密金鑰持有者所建立的資料。

檢查應用程式檔案

這個資料夾包含與步驟 2 相同的一組檔案，其中有兩個已變更的檔案和一個新檔案。新檔案是 `auth.py`，提供 `user()` 方法來檢索並驗證以加密編譯方式簽署的身分資訊。已變更的檔案是 `main.py` 和 `templates/index.html`，這兩個檔案目前採用上述方法得出的結果。此外，系統也會顯示在步驟 2 中發現的未驗證標頭，進行比較。

新功能主要位於 `user()` 函數中：

```
def user():
    assertion = request.headers.get('X-Goog-IAP-JWT-Assertion')
    if assertion is None:
        return None, None

    info = jwt.decode(
        assertion,
        keys(),
        algorithms=['ES256'],
        audience=audience()
    )

    return info['email'], info['sub']
```

assertion 是指特定要求標頭中提供的以加密編譯方式簽署的資料。該程式碼會使用程式庫驗證並解碼該資料。驗證作業採用 Google 提供的公開金鑰檢查相關簽署資料，並瞭解資料目標對象 (基本上是指受到保護的 Google Cloud 專案)。輔

助函式 `keys()` 和 `audience()` 會收集並傳回這些值。

簽署物件包含我們需要的兩種資料：經過驗證的電子郵件地址和專屬 ID 值 (以 `sub` 列出，表示訂閱者，位於標準欄位)。
這樣步驟 3 就完成了。

6. 摘要

您部署了 App Engine 網頁應用程式。在步驟 1 中，您將應用程式存取權限制為您選擇的使用者。在步驟 2 中，您檢索並顯示 IAP 允許應用程式存取權的使用者身分，也瞭解若停用或略過 IAP，該資訊可能會如何遭到冒用。在步驟 3 中，您驗證以加密編碼方式簽署的使用者身分斷言，這類斷言無法假冒。

步驟 7 · 約 0 分鐘

7. 清除所用資源

您在本程式碼研究室中使用的 Google Cloud Platform 資源只有 App Engine 執行個體。每次部署應用程式時，系統都會建立新版本，且新版本會持續存在，直到遭到刪除為止。離開實驗室即可刪除專案和其中的所有資源。
